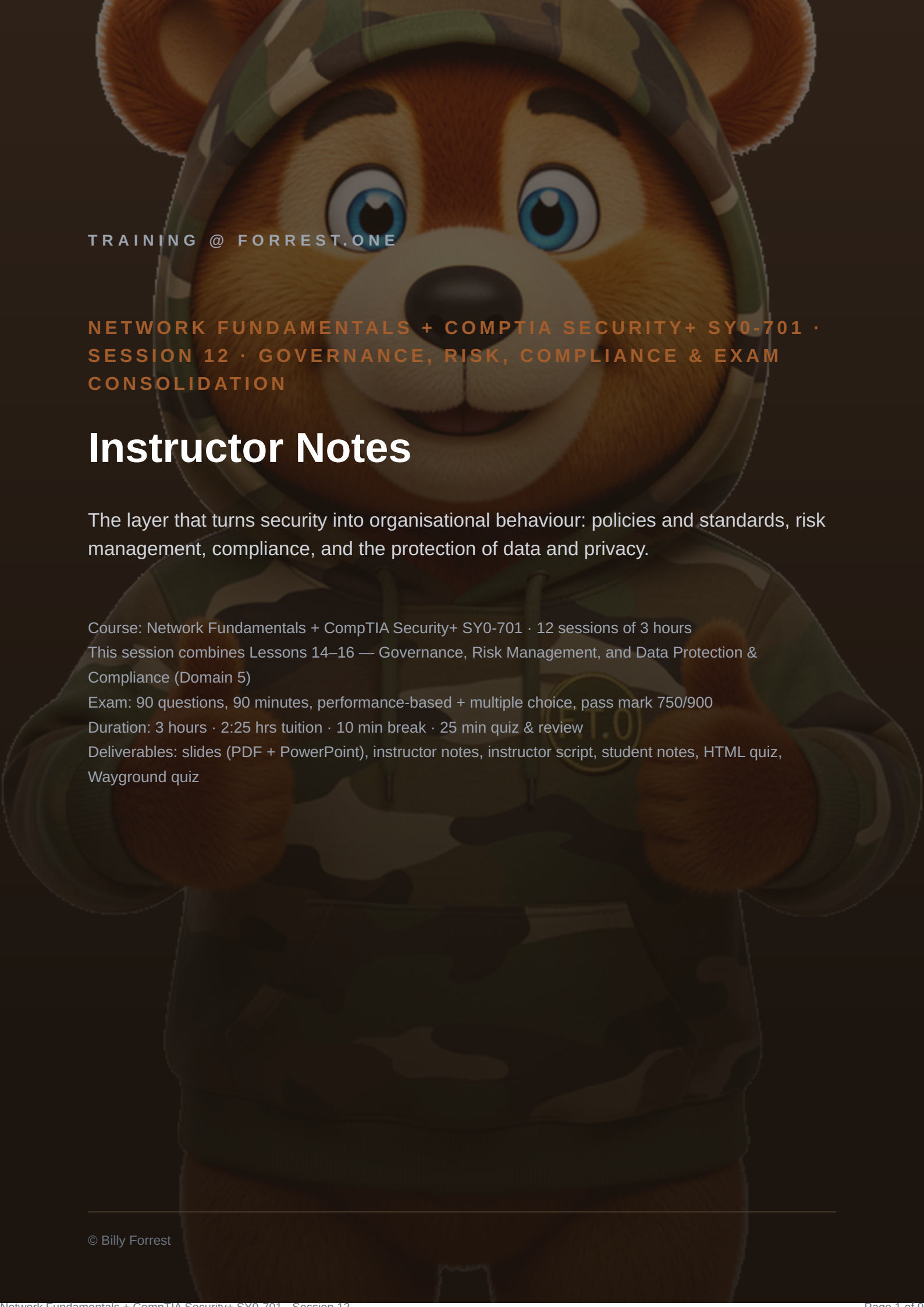




TRAINING @ FORREST.ONE

**NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 12 · GOVERNANCE, RISK, COMPLIANCE & EXAM
CONSOLIDATION**

Instructor Notes

The layer that turns security into organisational behaviour: policies and standards, risk management, compliance, and the protection of data and privacy.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session combines Lessons 14–16 — Governance, Risk Management, and Data Protection & Compliance (Domain 5)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Notes: Governance, Risk, Compliance & Exam Consolidation

A 3-hour delivery guide for Session 12, the course finale. This is a vocabulary-precise session: policy against standard, guideline against standard, appetite against tolerance, qualitative against quantitative, avoid against accept, owner against custodian, internal against external audit. Keep every definition crisp and every decision practical. Domain 5 carries 20% of the paper, so invest the time to make the distinctions stick. The session now runs six chapters, so watch the clock in the first half: governance and external obligations are vocabulary heavy, and the risk calculation must be worked on the board rather than read from the slide.

Session at a glance

Time	Block	Slides	Focus / activity
0:00–0:10	Welcome & objectives	1–2	Course position; the capstone framing
0:10–0:42	Chapter 1: Governance Foundations	3–8	Why governance first; structures; roles; document types; discussion
0:42–1:02	Chapter 2: External Obligations & Risk Identification	9–13	Regulation, contract, law; finding risks; likelihood and impact
1:02–1:25	Chapter 3: Risk Analysis & Treatment	14–18	SLE and ALE worked; the register; appetite; responses; activity
1:25–1:35	Break	19	10-minute break
1:35–1:55	Chapter 4: Risk Reporting & Vendors	20–24	Three audiences; BIA; vendor assessment, contracts, monitoring
1:55–2:10	Chapter 5: Compliance, Privacy & Audit	25–28	Frameworks; evidence; penalties and privacy; internal and external audit
2:10–2:25	Chapter 6: Assurance & Awareness	29–33	Attestation; penetration testing; awareness design, phishing, measurement
2:25–2:35	Data protection & exam consolidation	34–37	Classification, roles, privacy law; objective map
2:35–3:00	Quiz, takeaways & close	38–41	Quiz_Session_12.html; takeaways; exam booking

TOTAL: 2 hours 25 minutes of tuition plus a 10-minute break and 25 minutes of quiz and close, which is the 3-hour session stated on the cover.

Materials and preparation

- Projector or screen with the Session 12 slide deck (02_Slides.pdf or 02_Slides.pptx).
- One computer or tablet per pair for Quiz_Session_12.html (any browser, no internet required).
- Printed or digital copy of the Student Notes for each candidate.
- Whiteboard or flipchart for the risk calculation and the risk-response activity.
- The SY0-701 exam objectives for the final domain review, and the exam booking page if candidates are ready to book.

Delivery guidance by slide

Slides 1–2: Welcome (10 minutes)

Frame the session as the capstone. Governance sets direction, rules and accountability; risk management puts money on the things that could go wrong; compliance proves the work was done; awareness makes people part of the defence. Stress the shift in register: from here on, security is an organisational discipline rather than a set of tools. Ask the framing question early and keep returning to it: what has the business decided, and why?

Slides 3–8: Governance Foundations (32 minutes)

Start with why governance exists: it aligns security with business objectives, stops security being built in isolation, targets spending at what the business depends on, and sets the risk appetite everything else must respect. Use the financial institution example, which prioritises data protection and compliance because that is what its business rests on.

Structures next (slide 4). Walk the security committee as cross-functional, drawing in information technology, legal, human resources and operations, so policy is reviewed from every angle rather than one department view. Then draw the reporting line: the CISO reaches the chief executive or the board. Land the pair the exam separates: authority is the documented power to decide, approve or authorise; accountability is answering for the outcome, and audits reinforce it.

Roles (slides 5 and 6). Executive first: the CISO shapes strategy, develops policy, ensures compliance and manages risk, and translates technical problems into language executives can act on. Security directors own domains and contribute to incident response and recovery planning. The board must ensure a strategy exists and is genuinely implemented. Then operational: analyst on the front line, administrator running the infrastructure and audits, architect designing the framework. Close with data ownership, because it recurs in Domain 5: the data owner classifies the data and decides access and protection; the data custodian implements the controls.

Document types (slide 7) is the core exam distinction. Policy is a high-level statement of management intent. A standard turns that intent into a mandatory, measurable requirement, such as passwords of at least twelve

characters mixing letters, numbers and symbols. A guideline is recommended practice and is not mandatory. A procedure gives the exact steps for a task. Then the lifecycle: developed with stakeholders, approved by the right authority, distributed, and reviewed.

Discussion prompt (slide 8)

A password standard says twelve characters minimum; a guideline suggests passphrases. What is the difference in force? Probe the exam angle: the standard is mandatory and audits measure against it; the guideline is recommended and departures are acceptable if justified. Expect candidates to conflate the two, because both describe passwords.

Slides 9–13: External Obligations and Risk Identification (20 minutes)

Open with the framing sentence: security does not happen in a vacuum, and requirements arrive from regulators, from contracts and from the law. External obligations become internal policy, and internal policy becomes the controls that are deployed.

Regulatory requirements (slide 9): HIPAA requires administrative, physical and technical safeguards for electronic protected health information; PCI DSS demands strong access control and regular testing where card data is handled; NERC CIP protects energy critical infrastructure; GDPR covers personal data of people in the European Union wherever the organisation sits; CCPA gives Californians rights over personal information. Contracts (slide 10): a service level agreement can mandate encryption standards, incident response times and audits; a data processing agreement sets processor and controller duties with breach notification and audit rights; the NIST Cybersecurity Framework is the common contractual baseline. Then legal considerations (slide 11): liability, due diligence, jurisdiction and privacy law, which increasingly demands privacy by design, a data protection impact assessment and often a data protection officer.

Risk identification (slide 12). Start from the asset inventory, because you cannot protect what you have not listed. Key servers, databases and personnel each carry their own vulnerabilities. Threat modelling is the structured question, how could this system be attacked and what would the impact be, and a web application model naming injection attacks is the example to use. Vulnerability assessment uses scanning tools to find known weaknesses such as outdated software. Land the rule: you cannot manage a risk you have never named.

Assessment axes (slide 13). Likelihood is judged from the threat landscape and past incidents; impact covers financial loss, reputational damage and operational disruption. Two ways to express the result: qualitative ratings such as high, medium and low, which are quick and ideal for triage; and quantitative analysis using money and probabilities, which is precise but data hungry. Most organisations use both, and a hybrid scoring method is normal.

Slides 14–18: Risk Analysis, Registers and Treatment (23 minutes, then break)

Work the calculation on the board (slide 14) rather than reading it from the slide. Asset value one hundred thousand. Exposure factor forty percent. Single loss expectancy is asset value times exposure factor, so forty thousand. The annual rate of occurrence is zero point one, meaning once in ten years. Annualised loss expectancy multiplies that by the rate, so four thousand a year. Then make the point that matters

commercially: weigh the cost of a control against the loss it prevents. Say it in money and an executive will listen.

The register (slide 15) is a living document, not a compliance artefact. It describes each risk and the circumstances that trigger it, records a rating built from likelihood and impact, names a risk owner accountable for treatment, and tracks treatment status: monitored, mitigated, transferred or accepted. New risks are added, ratings are reassessed, and stakeholders across the business are engaged.

Appetite and tolerance (slide 16) is a favourite exam pair. Appetite is how much risk the organisation will pursue or retain to meet its objectives, so a regulated bank has a low appetite while a young technology company accepts far more to grow. Tolerance is how far it may drift from that appetite before action is taken. Use the worked example: a company accepts a five percent market share loss while chasing long term growth, but tolerates only a two percent deviation in a single quarter. Appetite sets the boundary; tolerance says how far you may drift inside it.

The four responses (slide 17): avoidance eliminates the risk by not doing the thing that creates it, which is effective but closes off the opportunity; transference shifts the burden through insurance or outsourcing and suits risks you lack the skill to manage; mitigation reduces likelihood or impact with controls, and that is the daily work; acceptance retains the risk knowingly when the control costs more than the impact. Stress that acceptance is a decision, not an accident, and must be documented.

Activity (slide 18)

Five scenarios, 8 minutes in pairs then 4 minutes debrief. Unpatchable legacy system: mitigate with compensating controls, or accept with documented sign-off. Flood risk at a data centre: transfer, via insurance. A board accepting a risk: the decision must be recorded with the owner and the reasoning. A supplier holding sensitive data: the contract must carry data handling, incident notification, audit rights and an exit plan. Debrief emphasises that mitigation is the everyday response and acceptance is always a management-level decision.

Slide 19: Break (10 minutes)

Announce what is coming: risk reporting and business impact, then vendors, compliance, audit and the awareness programme.

Slides 20–24: Risk Reporting, Business Impact and Vendors (20 minutes)

Reporting (slide 20) fails when everybody receives the same document. Technical teams need specific vulnerabilities, threat vectors, severity scores and patching plans. Executives need the business consequences, the effect on operations, finances and strategy, and they read charts rather than logs. The board and regulators want compliance, governance and plain language. The format follows the audience, whether a live dashboard, a detailed report or a short executive summary. Useful metrics: how often the risk occurs, how severe the impact is, and how far mitigation has progressed.

Business impact analysis (slide 21) is how you decide what really matters. It identifies the processes critical to operations, maps their dependencies in systems, applications and people, and assesses the consequences of disruption as financial, reputational or regulatory. The findings drive recovery priorities, so the most critical

functions are restored first, and they drive resource allocation, putting people, technology and budget where the impact would be greatest. That is how continuity planning earns its funding.

Vendor assessment (slide 22) begins well before the contract. A security questionnaire covers encryption, network security and incident response. Documentation review examines policies, procedures and compliance reports. An on site assessment is worth the trip where the relationship is significant, because it can expose a gap between documented practice and reality. Due diligence goes wider than security: financial stability, certifications, incident history and references. Crucially, assessment depth must match the risk. ISO 27001 and SOC 2 are the common markers of maturity.

Contracts (slide 23) are where vendor risk is actually controlled: how data is handled, stored and transmitted, including encryption standards and access controls; what counts as a security incident and how quickly the vendor must tell you, for example within one day of discovery; the right to audit, with scope and frequency; service level agreements carrying security metrics such as minimum uptime and response times for critical vulnerabilities; the agreement set (master service, data processing, non disclosure); and the exit, with data returned and remaining copies securely destroyed.

Monitoring (slide 24) matters because risk changes after signature. Periodic reassessment checks the vendor still meets your requirements; compliance verification confirms they follow the rules that apply; performance tracking uses agreed indicators for quality, timeliness and reliability. Rules of engagement set the boundaries of access, and that access follows least privilege, enforced with role based access control and multifactor authentication. Escalation procedures tell the vendor how to raise a problem, and a vendor breach still needs your incident plan.

Slides 25–28: Compliance, Privacy and Audit (15 minutes)

Define compliance plainly: adhering to the laws and standards that apply to you. Frameworks (slide 25) each have their own territory. PCI DSS governs cardholder data and demands a secure network, access control and regular testing. HIPAA protects medical information. Sarbanes Oxley protects investors by requiring accurate financial reporting and internal controls. GDPR covers personal data of people in the European Union. Decide what applies by industry, geography and data type, and remember that compliance is a baseline, not a finish line.

Monitoring (slide 26) is continuous, not a once a year exercise. Automated tools watch for violations as they happen: a security information and event management system collects and analyses security data and alerts on policy breaches, while configuration management keeps systems on approved settings and reverses drift. Manual review still matters, because interpretation of a regulation cannot be automated. Then evidence: the logs, audit trails and documentation that show controls working, protected against tampering and unauthorised access, and reported on through dashboards and metrics to regulators, auditors and management.

Non-compliance (slide 27) is expensive in several currencies: money, permission, trust and legal liability. Penalties under the data protection regulation can reach four percent of annual global turnover, or twenty million euro, whichever is greater. Regulators can impose sanctions or restrict processing, and in heavily regulated sectors remove the authority to operate. Privacy law adds duties: subject rights, informed consent and breach notification, with impact assessments finding risk before processing begins. Privacy compliance is about the individual, not the file.

Audits (slide 28) examine controls independently and check that reality matches the paperwork. An internal audit is performed by your own staff for self assessment, to find weaknesses, improve process and prepare for outside scrutiny. An external audit is performed by an independent third party, often because regulation demands it, giving customers assurance. Both follow the same four stages: plan with scope and objectives, gather evidence through documents, interviews and testing, report findings, then track remediation until each issue is closed.

Slides 29–33: Assurance, Testing and Awareness (15 minutes)

Two forms of assurance (slide 29). Attestation is a formal declaration that controls meet stated criteria, and the common example is a Service Organization Control report: SOC 1 covers controls relevant to financial reporting, SOC 2 covers security, availability, processing integrity, confidentiality and privacy, which is what cloud providers are asked for, and SOC 3 gives the same picture at a high level. Certification statements against ISO 27001 are the other form. Penetration testing goes further, attacking the system with permission in black box, white box or grey box form, with scope and rules of engagement agreed first, then findings prioritised, remediated and retested.

Awareness is programme design, not a single slide deck (slide 30). Start with audience analysis: which roles touch sensitive data, what they already know, where the gaps are. Set objectives that are specific, measurable and time bound, such as being able to identify and report a phishing email. Content should be current and recognisable, built from real incidents and interactive scenarios. Delivery can be computer based for scale, instructor led for depth, or a campaign of reminders, tailored by role. Measure with assessments, simulations and reporting rates.

Phishing (slide 31) is the attack most likely to reach your users, so train for it directly. Teach recognition: a suspicious sender, manufactured urgency, an unexpected attachment, a link to an unfamiliar site. Teach reporting with one obvious route. Then simulate: send campaigns without warning and measure click rates and reporting rates, with progressive difficulty from obvious scams to business email compromise, and immediate feedback that explains what the user missed. Balance intensity with experience, because too many simulations cause fatigue.

Guidance (slide 32) only works if it is practical, so translate policy into behaviour: a password standard becomes advice about length and a password manager that makes compliance easy. Reinforce with short reminders and just in time training when a new campaign appears. Make reporting effortless through a mailbox, a phone line or an anonymous portal, and thank the person who reports, because punishment destroys your early warning. Then teach the anomalies to report: unsolicited requests, impersonation, urgency, unusual access, disgruntlement, data hoarding, unescorted strangers and unattended devices.

Measurement (slide 33) answers whether the programme works. Assessments test whether people can recognise a threat; simulations show how they behave under a realistic attack; incident metrics show what users are reporting and how quickly. Analyse the results for trends and gaps, refresh the content with recent incidents and current threat intelligence, ask the audience what is not working, and vary the channels so the message stays visible. Awareness fades fast, and a programme that never changes is measuring a threat that has moved on.

Slides 34–37: Data protection and exam consolidation (10 minutes)

Data protection closes the practical content. Classification (slide 34) drives the controls: public, internal, confidential and restricted, with the higher class receiving stronger protection, and the three states, at rest, in transit and in use, each needing their own controls. Roles (slide 35): the data owner is accountable for classification, access and protection; the data steward ensures quality and governance day to day; the data custodian implements the technical controls. Then the lifecycle, collect, store, use, share, archive and destroy, with a retention policy that answers how long and why, and secure destruction at the end of it. Privacy law and sovereignty (slide 36): GDPR and UK GDPR principles and rights, informed consent, the breach duty, and the fact that data answers to the law of the jurisdiction where it resides.

Exam alignment (slide 37) maps the whole session to four objective areas and closes the five-domain map for the course. Read the table as a revision checklist rather than a slide to teach from.

Slides 38–41: Quiz, takeaways and close (25 minutes)

Walk the takeaways, run the quiz, then review low scores. Give the exam step as a next action rather than an aspiration: revise the five domains, re-take the earlier session quizzes as a full sweep, practise performance based questions, and book. Emphasise the exam pairs one last time: policy against standard, standard against guideline, appetite against tolerance, qualitative against quantitative, owner against custodian, internal against external audit, avoid against accept. Close the course warmly and positively.

Common misconceptions and corrections

Misconception	Correction
Policy and standard are the same	Policy states intent; standards set mandatory requirements
Guidelines are mandatory	Guidelines are recommended, and flexible by design
Authority and accountability are the same	Authority is the power to decide; accountability is answering for the outcome
Appetite and tolerance mean the same thing	Appetite sets the boundary; tolerance is the drift allowed inside it
Accepting risk is failure	Acceptance is a valid, documented management decision
Quantitative is always better	Qualitative is faster; quantitative needs reliable data
The risk register is written once	It is a living document, with owners, ratings and reviews
A vendor breach is the vendor's problem	You inherit the vendor's weaknesses, so monitor and rehearse your own response
Internal audit is a waste of time	It finds weaknesses and prepares you for external scrutiny
Attestation proves security	Attestation declares; penetration testing actively tests
Simulate phishing as hard as possible	Too many simulations cause fatigue and destroy the reporting habit
Delete equals destroy	

Misconception	Correction
	Secure destruction at end of retention is required for sensitive data
Compliance equals security	Compliance sets a baseline; security must go beyond it
Data owner stores the data	Owner is accountable; custodian implements controls

Exam alignment check

- All session objectives map to Domain 5 objectives.
- Quiz tags map every question to its exam objective for traceable revision.
- Decision scenarios in the quiz mirror the exam's governance and risk style.
- Performance-based items may ask you to sequence the risk process, choose a response, or pick the right document type.
- Revise the exam pairs cold: policy and standard, standard and guideline, appetite and tolerance, qualitative and quantitative, owner and custodian, internal and external audit, avoid and accept.